

Cyber Threat Intelligence

Executive Briefing

Report Date: July 23, 2026

Generated: 2026-07-23 16:42 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
5	13	2	0	20

2. Executive Summary

On July 23, 2026, the Cyber Threat Intelligence division analyzed a total of 20 vulnerabilities, consisting of a severity breakdown of 5 Critical, 13 High, 2 Medium, and 0 Low findings. The current organizational risk posture remains critical, driven by a concentration of high-severity flaws that threaten core enterprise architecture. The primary operational risk stems from CVE-2026-64649, Server-Side Request Forgery in Next.js Server Actions, which demands immediate remediation due to its high urgency score and potential for unauthorized internal network access. Leadership must enforce an immediate defensive posture involving rapid patching and mitigation deployment across all affected systems. All engineering and security operations teams are directed to execute the mandatory mitigations detailed in the critical action list within the stipulated timeframes.

3. Critical Action List

- Execute an immediate patch deployment for CVE-2026-64649 (Server-Side Request Forgery in Next.js Server Actions) across all custom server deployments within 24 hours.
- Implement security updates for CVE-2026-64642 (Middleware and Proxy Bypass in Next.js App Router) to secure Turbopack configurations within 24 hours.
- Apply vendor-supplied patches for CVE-2026-10050 (Digest Authentication Bypass via ISO-8859-1 Encoding in Eclipse Jetty) within 24 hours to prevent unauthorized access.
- Deploy mitigation controls for CVE-2026-64648 (Cache Confusion in Next.js Response Bodies) within 48 hours to secure HTTP request handling.
- Remediate CVE-2026-64645 (SSRF in Next.js Rewrites via Destination Hostname) by updating application rewrite configurations within 48 hours.
- Initiate remediation for remaining High-severity vulnerabilities within 72 hours in accordance with organizational risk thresholds.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-64649	Server-Side Request Forgery in Ne...	9.8	Critical	88/100	CWE-918
CVE-2026-64642	Middleware and Proxy Bypass in Ne...	9.8	Critical	88/100	CWE-285
CVE-2026-10050	Digest Authentication Bypass via ...	9.8	Critical	88/100	CWE-173
CVE-2026-64648	Cache Confusion in Next.js Respon...	9.1	Critical	82/100	CWE-524
CVE-2026-64645	SSRF in Next.js Rewrites via Dest...	9.1	Critical	82/100	CWE-918
CVE-2026-59822	MCP Authentication Bypass in Lite...	8.2	High	74/100	CWE-287
CVE-2026-65589	Credential Leakage in n8n LLM Nod...	8.1	High	73/100	CWE-532
CVE-2026-64647	Cache Confusion via Invalid UTF-8...	7.5	High	68/100	CWE-116
CVE-2026-64646	Unbounded Server Action Payload i...	7.5	High	68/100	CWE-770
CVE-2026-64644	Denial of Service in Next.js Imag...	7.5	High	68/100	CWE-407
CVE-2026-64643	Unauthenticated Disclosure of Ser...	7.5	High	68/100	CWE-201
CVE-2026-64641	Denial of Service in Next.js App ...	7.5	High	68/100	CWE-834
CVE-2024-7708	OutOfMemory Denial of Service in ...	7.5	High	68/100	CWE-400
CVE-2026-10051	Cross-Request Trailer Leakage in ...	7.5	High	68/100	CWE-200
CVE-2026-59943	Filesystem Enumeration in Dompdf ...	7.5	High	68/100	CWE-209
CVE-2026-59942	Denial of Service in Dompdf via O...	7.5	High	68/100	CWE-400
CVE-2026-59941	Resource Consumption in Dompdf vi...	7.5	High	68/100	CWE-400
CVE-2026-59821	Custom Code Guardrails Bypass in ...	7.2	High	65/100	CWE-94
CVE-2026-8384	Path Parameter Traversal in Eclip...	5.3	Medium	48/100	CWE-647
CVE-2026-6790	HTTP Authority and Host Mismatch ...	5.3	Medium	48/100	CWE-20

5. Detailed Vulnerability Findings

CVE-2026-64649

Finding: Server-Side Request Forgery in Next.js Server Actions

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-918

Score Provenance: Tenable Verified

MITRE ATT&CK: T1190, T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Next.js contains a server-side request forgery vulnerability within Server Actions when deployed on custom servers. The framework fails to adequately validate or restrict URLs supplied via attacker-controlled parameters in server-side handlers. Consequently, an unauthenticated remote attacker can induce the server to dispatch arbitrary outbound HTTP requests to internal or external systems.

Proof of Concept (PoC):

An unauthenticated remote attacker targets a Next.js custom server deployment utilizing vulnerable Server Actions. The attacker sends an HTTP POST request to the application endpoint with an internal target URL supplied within the action input parameters. The server processes the request and executes an outbound connection to internal network resources without validation. This results in the unauthorized retrieval of internal service data and metadata information.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-64649>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-64649>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-64649>

CVE-2026-64642

Finding: Middleware and Proxy Bypass in Next.js App Router

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-285

Score Provenance: Tenable Verified
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Next.js contains a security bypass vulnerability in App Router applications utilizing Turbopack and a single locale configuration. The routing middleware and proxy validation logic incorrectly evaluate path matching constraints under specific locale setups. An unauthenticated remote attacker can bypass access control checks and reach protected application routes.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request with manipulated locale path segments to a Next.js App Router endpoint. The proxy and middleware layers fail to enforce authentication and routing restrictions due to faulty string normalization. This results in unauthorized access to restricted backend application pages.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-64642>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-64642>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-64642>

CVE-2026-10050

Finding: Digest Authentication Bypass via ISO-8859-1 Encoding in Eclipse Jetty

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-173

Score Provenance: Tenable Verified
MITRE ATT&CK: T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Eclipse Jetty Digest Authentication contains an authentication bypass vulnerability caused by lossy ISO-8859-1 character encoding conversions. The credential verification routine performs unsafe character substitutions during digest validation. An unauthenticated remote attacker can bypass authentication checks by crafting credentials containing substituted characters.

Proof of Concept (PoC):

An unauthenticated remote attacker submits an HTTP request to a Jetty-protected resource using a crafted Digest Authorization header containing characters that map equivalently under ISO-8859-1 truncation. The authentication module evaluates the mangled string as a valid match for legitimate user credentials. This results in complete authentication bypass and unauthorized administrative access.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-10050>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-10050>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-10050>

CVE-2026-64648**Finding: Cache Confusion in Next.js Response Bodies**

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-524

Score Provenance: Tenable Verified

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Next.js exhibits a cache confusion vulnerability affecting response bodies for HTTP requests containing bodies. The caching mechanism improperly associates cached responses across distinct requests due to insufficient differentiation of request body characteristics. This flaw enables attackers to cause cache poisoning or receive unintended cached response content belonging to other users.

Proof of Concept (PoC):

An unauthenticated remote attacker crafts an HTTP request containing a specialized request body directed at the Next.js caching layer. The server handles the caching operation without incorporating the request body contents into the cache key generation logic. This results in subsequent users receiving incorrectly matched cached responses containing sensitive information.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-64648>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-64648>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-64648>

CVE-2026-64645

Finding: SSRF in Next.js Rewrites via Destination Hostname

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-918

Score Provenance: Tenable Verified
MITRE ATT&CK: T1190, T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Next.js contains a server-side request forgery vulnerability in application rewrites via attacker-controlled destination hostnames. The routing engine insufficiently validates target host headers and redirection URLs defined within rewrite rules. Consequently, an unauthenticated remote attacker can force the server to proxy requests to internal infrastructure.

Proof of Concept (PoC):

An unauthenticated remote attacker crafts an HTTP request targeting a Next.js rewrite configuration containing dynamic parameters. The attacker manipulates the destination hostname parameter to point to an internal loopback or metadata service endpoint. The server proxies the request directly to the malicious destination without restriction. This results in unauthorized disclosure of internal service responses.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-64645>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-64645>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-64645>

CVE-2026-59822

Finding: MCP Authentication Bypass in LiteLLM via OAuth2 Passthrough Fallback

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-287

Score Provenance: Tenable Verified
MITRE ATT&CK: T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

LiteLLM suffers from an authentication bypass vulnerability in Model Context Protocol (MCP) endpoints due to an insecure OAuth2 passthrough fallback mechanism. The authentication handler incorrectly falls back to permissive trust states when encountering malformed or missing OAuth2 tokens. An unauthenticated remote attacker can exploit this

fallback logic to gain unauthorized access to protected MCP services.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an API request to a LiteLLM MCP endpoint omitting valid OAuth2 credentials while supplying fallback headers. The authentication subsystem evaluates the fallback condition and incorrectly grants access to the requesting client. This results in unauthorized access to internal model management and context features.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-59822>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-59822>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-59822>

CVE-2026-65589

Finding: Credential Leakage in n8n LLM Node Execution Data

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 73/100 | CWE: CWE-532

Score Provenance: Tenable Verified
MITRE ATT&CK: T1552, T1213

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

n8n contains an information disclosure vulnerability where custom header credential values are leaked in plaintext into LLM node execution logs and storage data. The execution logging engine fails to sanitize sensitive header parameters before persisting node state. Consequently, authenticated users with read access to workflow execution histories can view sensitive API keys and credentials.

Proof of Concept (PoC):

An authenticated low-privileged user triggers an execution of an n8n workflow containing an LLM node configured with custom authentication headers. The application records the complete request context including plaintext authorization headers into the execution history database. This results in the exposure of sensitive third-party API credentials to users with workflow viewing permissions.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-65589>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-65589>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-65589>

CVE-2026-64647

Finding: Cache Confusion via Invalid UTF-8 Sequences in Next.js

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-116

Score Provenance: Tenable Verified
MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
---------------	---------

Attack Complexity	Low
-------------------	-----

Privileges Required	None
Scope	Unchanged
Integrity Impact	None

User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Next.js is vulnerable to cache confusion regarding response bodies for requests featuring bodies containing invalid UTF-8 byte sequences. The normalization and sanitization routines fail to properly handle malformed UTF-8 inputs prior to caching operations. An unauthenticated attacker can exploit this inconsistency to pollute or manipulate the caching mechanism.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP request with a body containing malformed UTF-8 byte sequences to the Next.js server. The application's caching parser misinterprets the encoding boundaries while storing the response entity. This results in integrity degradation of cached content across user sessions.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-64647>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-64647>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-64647>

CVE-2026-64646

Finding: Unbounded Server Action Payload in Next.js Edge Runtime

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Next.js suffers from an uncontrolled resource consumption vulnerability involving unbounded Server Action payloads executed within the Edge runtime. The platform lacks proper enforcement of payload size limits during the ingestion of server action data streams. An unauthenticated remote attacker can exhaust server memory and computational resources by submitting excessively large payloads.

Proof of Concept (PoC):

An unauthenticated remote attacker submits a multipart POST request with an extremely large payload size to a Next.js Server Action running on the Edge runtime. The Edge runtime processes the incoming stream without enforcing maximum length restrictions, allocating continuous memory buffers. This results in resource exhaustion and denial of service for legitimate application users.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-64646>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-64646>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-64646>

CVE-2026-64644

Finding: Denial of Service in Next.js Image Optimization API via SVGs

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-407

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

Next.js is vulnerable to a denial of service condition in the Image Optimization API when processing malicious Scalable Vector Graphics (SVG) files. The image parser performs expensive nested XML expansions and recursive operations without adequate complexity limits. An unauthenticated remote attacker can trigger excessive CPU consumption by supplying a crafted SVG image.

Proof of Concept (PoC):

An unauthenticated remote attacker submits an HTTP request to the Next.js image optimization endpoint referencing a maliciously structured SVG file. The rendering engine parses the deeply nested entity definitions and XML structures without depth restrictions. This results in high CPU utilization and application unavailability.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-64644>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-64644>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-64644>

CVE-2026-64643

Finding: Unauthenticated Disclosure of Server Function Endpoints in Next.js

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-201

Score Provenance: Tenable Verified

MITRE ATT&CK: T1592, T1046

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

Next.js allows unauthenticated disclosure of internal Server Function endpoints due to improper access controls. The application fails to restrict endpoint metadata visibility and routing maps from public exposure. As a result, unauthenticated remote attackers can enumerate internal server functions and application architecture.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted HTTP request to internal Next.js manifest endpoints. The application returns the complete mapping of internal Server Functions without verifying user authentication. This results in the disclosure of sensitive implementation details to unauthorized parties.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-64643>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-64643>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-64643>

CVE-2026-64641

Finding: Denial of Service in Next.js App Router via Server Actions

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-834

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Next.js App Router applications are vulnerable to a denial of service condition when handling recursive or looping Server Actions. The execution framework lacks adequate protection against unbounded iterative operations triggered via server action inputs. An unauthenticated remote attacker can exhaust system thread pools and cause application crashes.

Proof of Concept (PoC):

An unauthenticated remote attacker initiates a series of heavily nested Server Action requests to the Next.js App Router backend. The application processes the recursive execution loop without enforcing depth thresholds or circuit breakers. This results in thread starvation and complete denial of service for all users.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-64641>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-64641>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-64641>

CVE-2024-7708

Finding: OutOfMemory Denial of Service in Eclipse Jetty

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: CVE.org Verified
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Eclipse Jetty contains an uncontrolled resource consumption vulnerability in the HTTP connection handler when processing 100-Continue requests. The server allocates persistent buffers or tracking structures for expectation headers without proper bounds or cleanup mechanisms. An unauthenticated remote attacker can trigger an OutOfMemory error

by flooding the server with specially crafted expectation requests.

Proof of Concept (PoC):

An unauthenticated remote attacker establishes multiple TCP connections to the Eclipse Jetty server, sending HTTP headers containing Expect: 100-continue without subsequent body data. The server retains connection state structures indefinitely without timing out or releasing memory allocations. This results in heap exhaustion and an OutOfMemory crash affecting all hosted services.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2024-7708>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2024-7708>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2024-7708>

CVE-2026-10051

Finding: Cross-Request Trailer Leakage in Eclipse Jetty HTTP/1.1 Connections

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: Tenable Verified
MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Eclipse Jetty exhibits a cross-request information leakage vulnerability for HTTP trailers on persistent HTTP/1.1 keep-alive connections. The connection pooling and buffer management logic fails to clear trailer header state between sequential requests on the same socket. Consequently, an unauthenticated remote attacker can potentially read trailer data intended for other clients sharing the connection.

Proof of Concept (PoC):

An unauthenticated remote attacker establishes an HTTP/1.1 keep-alive connection with Eclipse Jetty and issues multiple pipelined requests. The server retains residual HTTP trailer fields in internal buffer structures across request boundaries. This results in the exposure of sensitive header data to subsequent requests on the same socket.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-10051>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-10051>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-10051>

CVE-2026-59943

Finding: Filesystem Enumeration in Dompdf via Embedded SVG

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-209

Score Provenance: Tenable Verified
MITRE ATT&CK: T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
---------------	---------

Attack Complexity	Low
-------------------	-----

Privileges Required	None
Scope	Unchanged
Integrity Impact	None

User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Dompdf is vulnerable to an information disclosure flaw when processing embedded SVG images that leak the existence of local files and directories. The rendering engine evaluates external references within SVG documents without adequate sandbox restrictions. An attacker supplying a crafted HTML document can determine whether specific file paths exist on the server filesystem based on rendering errors.

Proof of Concept (PoC):

An unauthenticated remote attacker submits an HTML document containing an embedded SVG referencing local file paths via the Dompdf generation endpoint. The rendering library processes the SVG tags and leaks path existence through distinct error messages or layout differences in the output PDF. This results in unauthorized filesystem reconnaissance.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-59943>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-59943>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-59943>

CVE-2026-59942

Finding: Denial of Service in Dompdf via Oversized Image Bitmaps

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Dompdf suffers from a denial of service vulnerability caused by uncontrolled resource consumption when processing oversized image bitmaps. The image decoding module lacks checks for maximum dimension limits before allocating memory for pixel buffers. An attacker can exhaust server memory by embedding extremely large image bitmaps within documents.

Proof of Concept (PoC):

An unauthenticated remote attacker generates a PDF document via Dompdf containing an image tag pointing to a maliciously crafted bitmap with massive header dimensions. The application attempts to allocate memory corresponding to the declared image size without validation. This results in memory exhaustion and application termination.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-59942>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-59942>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-59942>

CVE-2026-59941

Finding: Resource Consumption in Dompdf via BMP Dimensions

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

Dompdf contains an uncontrolled resource consumption vulnerability based on declared BMP image dimensions. The image parsing logic allocates memory buffers directly proportional to header dimensions without verifying file bounds or limits. An attacker can trigger excessive memory consumption by supplying a BMP image with manipulated header dimensions.

Proof of Concept (PoC):

An unauthenticated remote attacker submits an HTML payload to Dompdf containing a BMP image reference with forged header dimensions. The image parser reads the width and height values and allocates massive memory pools without checking actual stream lengths. This results in server-side resource exhaustion and denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-59941>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-59941>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-59941>

CVE-2026-59821

Finding: Custom Code Guardrails Bypass in LiteLLM

CVSS v3.1 Score: 7.2 | Severity: High | Urgency Score: 65/100 | CWE: CWE-94

Score Provenance: Tenable Verified

MITRE ATT&CK: T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	High	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	High

Description:

LiteLLM contains a security bypass vulnerability in custom code guardrail production endpoints that allows the circumvention of safety checks. The validation framework fails to properly enforce guardrail execution paths when processing specific request configurations on production APIs. Consequently, an attacker can bypass defined code safety checks and execute restricted LLM operations.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an API request to a LiteLLM production endpoint configured with custom code guardrails. The attacker includes specific parameter flags that cause the evaluation middleware to skip the

guardrail validation function. This results in the execution of unsafe LLM payloads without security filtering.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-59821>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-59821>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-59821>

CVE-2026-8384

Finding: Path Parameter Traversal in Eclipse Jetty

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-647

Score Provenance: CVE.org Verified
MITRE ATT&CK: T1083, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Eclipse Jetty is vulnerable to path parameter traversal due to improper parsing of URI path segments. The HTTP request mapping engine incorrectly interprets path parameters and matrix variables, allowing access to resources outside the intended web root. An unauthenticated remote attacker can bypass directory restrictions to read unauthorized files.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP GET request containing encoded path parameters and traversal sequences like ;/./ in the URI. The Jetty request dispatcher fails to sanitize the matrix parameters before resolving the physical resource path. This results in unauthorized access to restricted application endpoints.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-8384>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-8384>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-8384>

CVE-2026-6790

Finding: HTTP Authority and Host Mismatch in Eclipse Jetty

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-20

Score Provenance: CVE.org Verified
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Eclipse Jetty suffers from an HTTP Authority/Host header mismatch vulnerability in request parsing routines. The server fails to consistently validate and reconcile discrepancies between the Host header and the request authority components. An unauthenticated remote attacker can exploit this discrepancy to bypass security controls or poison web caches.

Proof of Concept (PoC):

An unauthenticated remote attacker transmits an HTTP request to Eclipse Jetty where the Host header differs from the authority specified in the request line. The server processes the request using conflicting host contexts without validation. This results in improper routing and potential security control bypass.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-6790>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-6790>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-6790>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>